Lab 3: Architectural Pattern Selection & Justification

Patient Health Record Consent Management System

SRN: PES2UG24CS015

Name: Aarushi Singh

Architecture Selection

We chose Layered Architecture for the Patient Health Record Consent Management System.

Why this architecture makes sense here

This system exists to let patients control exactly who can see their medical records, for how long, and for what purpose. Every access request has to pass through the same fixed sequence of checks before a doctor, lab, or clinic ever touches a record: verify the requester's identity, confirm a valid and unexpired consent exists for that specific record, and log the outcome permanently. That kind of strict, ordered, rule-driven flow - patient action -> business-rule validation -> durable storage - maps naturally onto layers, where each layer only talks to the one beneath it and no request can skip a step.

Reason 1 - Clear separation between UI, consent/access rules, and data: Patients and healthcare providers interact only through the Presentation layer (the UI component), while all the actual decision-making - validating consent scope, verifying provider identity, and writing audit entries - lives in the Business layer. This means the patient-facing app or a clinic's provider portal can be redesigned later without touching how consent validation or auditing works underneath.

Reason 2 - Predictable, sequential authorization flow: Consent-based record access does not need every component reacting independently to unpredictable traffic the way, say, a social media feed would. Every access attempt always follows the same order (identity verification -> consent validation -> audit logging -> record release), so a layered structure that enforces this sequencing top-to-bottom fits better than the added operational complexity of microservices, and it is simpler to build and test than a full client-server split.

Security Advantage

Because the Business layer sits between the UI and the Data layer, no request from a patient or a healthcare provider can touch the database directly - every action (granting consent, revoking it, or a provider requesting a record) has to pass through the Consent Manager, Provider Verification, and Access Validation components first. This gives the system one clear checkpoint where a rule like “a provider may only access a record if their identity is verified AND an active, unexpired, correctly-scoped consent exists” is enforced consistently, instead of relying on the UI or the provider's own system to behave correctly. It also means the append-only Audit Logger Component can guarantee that every grant, revoke, and access event is recorded, since all such events are forced through the same business-layer checkpoint.

Performance Benefit

Since Provider Verification, Access Validation, and Audit Logging are separated out as their own components within the Business layer, a slower identity check or a delay in writing an audit entry does not block unrelated actions - such as a patient simply viewing their list of active consents through the UI component. Each component only does its one job, so consent-validation and access-logging operations (which NFR-002 requires to complete within 2 seconds for 95% of requests) are not forced to wait on unrelated parts of the system before completing.